

CISSP Printable Practice Exam 30 - Domain 6 - Security Assessment and Testing

Practice Exam 04 - Domain 6

Choose the best answer for each question. For multi-select items, select all required answers.

Question 1 (CISSP4-099)

Scenario: A global publisher has separate security, compliance, risk, and internal audit teams. Each team reviews access controls independently, while no team assesses the security of several critical data exchanges between business units.

What should the chief audit executive recommend FIRST?

- A. Assign every oversight team to repeat the same access-control tests each quarter.
- B. Create an assurance map linking risks and control objectives to responsible reviewers, then address overlaps and uncovered areas.
- C. Remove the data exchanges from the audit universe because no team currently owns them.
- D. Allow each team to define assurance solely from its existing checklist.

Question 2 (CISSP4-100)

Scenario: A brokerage operates in a jurisdiction where a regulatory retention requirement is stricter than the organization's global security baseline. An assessor is planning a compliance audit of records generated in that jurisdiction.

Which criterion should govern the assessment conclusion?

- A. The less demanding requirement because it is easier to apply consistently.
- B. The global baseline only, because internal documents supersede external obligations.
- C. The preference of the system owner, documented after testing is complete.
- D. The applicable regulatory requirement, with the internal baseline also assessed where relevant.

Question 3 (CISSP4-101)

Scenario: A benefits platform relies on a subcontracted data center for physical and environmental controls. The platform provider's independent assurance report excludes the data center's controls and states that customers must evaluate that subservice organization separately.

What is the customer's BEST next action?

- A. Obtain and evaluate appropriate assurance for the excluded data center controls before concluding on the full service risk.
- B. Assume the excluded controls are effective because the platform provider selected the subcontractor.
- C. Treat the platform report as if it included every control performed by the data center.
- D. Ignore physical and environmental controls because they are operated by a third party.

Question 4 (CISSP4-102)

Scenario: A regional water authority is preparing an internal assessment of administrative access to operational support systems. Previous reviews were delayed because control owners disputed evidence requests and test responsibilities after fieldwork began.

Which TWO planning actions would BEST prevent the same problem? Select 2 of the 5 options

below.

- A. Obtain approval of the scope, objectives, authority, and escalation path before fieldwork.
- B. Agree on evidence owners, required artifacts, and delivery timelines with responsible stakeholders.
- C. Allow each control owner to remove unfavorable samples after testing begins.
- D. Avoid documenting test procedures so assessors can change conclusions freely.
- E. Assign remediation decisions to the assessors before any findings exist.

Question 5 (CISSP4-103)

Scenario: A construction company continuously collects configuration status from managed endpoints. During a scheduled audit, the assessor wants to use the dashboard history as evidence that endpoint controls operated throughout the review period.

What should the assessor do BEFORE relying on the dashboard history?

- A. Accept the dashboard because continuous collection eliminates the need to validate evidence quality.
- B. Use only the current dashboard screen and disregard the defined audit period.
- C. Verify data sources, population coverage, collection logic, integrity, and exception handling for the period under review.
- D. Convert the audit into a continuous monitoring function operated by the assessor.

Question 6 (CISSP4-104)

Scenario: During an internal security audit, management refuses access to records for a high-risk subsidiary that is explicitly included in the approved scope. Alternative procedures cannot provide equivalent evidence.

What is the auditor's BEST course of action?

- A. Issue an unqualified conclusion because most other business units were tested.
- B. Document and escalate the scope limitation, then modify the conclusion to reflect the missing evidence.
- C. Remove the subsidiary from the approved scope without informing governance stakeholders.
- D. Assume the subsidiary's controls match those of the tested business units.

Question 7 (CISSP4-105)

Scenario: A travel marketplace allows users to reset passwords through a support-assisted recovery process. The assessment objective is to determine whether an attacker can take over an account using publicly available information and repeated support contacts.

Which test would BEST address the objective?

- A. Confirm that legitimate users can reset their passwords when all verification data is correct.
- B. Review only the written support procedure for required identity checks.
- C. Measure the average time required for a normal password reset.
- D. Attempt authorized recovery misuse scenarios using incomplete, guessed, and inconsistent identity evidence across repeated contacts.

Question 8 (CISSP4-106)

Scenario: A securities firm is testing whether authentication events from an application, identity service, and central repository can support reliable investigations. Reviewers suspect that clock differences and dropped records may distort event sequences.

Which procedure provides the STRONGEST evidence?

- A. Generate controlled authentication events, trace them through all three sources, and compare record completeness and normalized timestamps.
- B. Confirm that each system has a written logging standard.
- C. Count repository events without identifying expected source records.
- D. Ask system owners whether their clocks are usually accurate.

Question 9 (CISSP4-107)

Scenario: A code review of an internal automation service finds a database password stored in a configuration constant committed to the source repository. Developers state that the repository is private.

What is the MOST appropriate assessment conclusion?

- A. The password is adequately protected because only employees can access the repository.
- B. The issue is limited to code style and has no security effect.
- C. The embedded secret should be removed, rotated, and managed through an approved protected mechanism with access logging.
- D. The password may remain if the source file is renamed.

Question 10 (CISSP4-108)

Scenario: An insurance portal lets customers upload supporting documents. The security test must determine whether validation can be bypassed and whether uploaded content can escape its intended storage location.

Which TWO tests are MOST relevant? Select 2 of the 5 options below.

- A. Submit files with misleading extensions, mismatched content types, and prohibited executable content.
- B. Test crafted filenames and paths to verify normalization and storage-boundary enforcement.
- C. Compare the portal's colors with the organization's branding guide.
- D. Measure how quickly a valid small document appears in the user's history.
- E. Count the number of words in the upload instructions.

Question 11 (CISSP4-109)

Scenario: A penetration tester gains authorized access to a production database containing customer records. The engagement requires proof that restricted data is reachable but prohibits unnecessary collection of personal information.

What should the tester do NEXT?

- A. Export the entire database so management can see the maximum possible impact.
- B. Capture the minimum approved evidence needed to demonstrate access, protect it, and follow the notification procedure.
- C. Modify several customer records to prove write access even though that objective was not approved.
- D. Publish a screenshot to the assessment team before applying evidence-handling controls.

Question 12 (CISSP4-110)

Scenario: A research company deploys servers from an approved hardened image. Months later, the assurance team must determine whether operational changes have caused the active servers to drift from the required configuration.

Which test is MOST appropriate?

- A. Confirm that the original image passed review and assume all derived servers remain compliant.
- B. Review purchase records for the physical hosts supporting the servers.
- C. Ask administrators whether they remember changing security settings.
- D. Compare current server configurations with the approved baseline and validate authorized exceptions.

Question 13 (CISSP4-111)

Scenario: An auditor is assessing service-account governance after several application teams were reorganized. The directory lists account names and last-use dates, but many ownership fields are blank or refer to former departments.

Which analysis would provide the MOST useful evidence?

- A. Reconcile service accounts to current applications and accountable owners, then investigate active accounts without valid ownership or purpose.
- B. Count all directory accounts and compare the total with the previous year.
- C. Review only accounts whose names include the word service.
- D. Assume recently used accounts are authorized because they support active processes.

Question 14 (CISSP4-112)

Scenario: A monthly report shows that the total number of overdue high-risk findings remains below the enterprise threshold. However, overdue findings affecting internet-facing services have increased for four consecutive months.

What is the BEST interpretation?

- A. No risk escalation is needed because the enterprise total remains below its threshold.
- B. The trend is irrelevant until the total exceeds the enterprise threshold.
- C. The segment trend may indicate increasing exposure and should be analyzed against an appropriate risk threshold.
- D. The report proves that remediation performance is improving across all systems.

Question 15 (CISSP4-113)

Scenario: During a scheduled assessment, an automated test reports that a web security control failed for one request. Application records show the request was denied, while the test tool recorded an unexpected response code.

What should the assessor do FIRST?

- A. Report a confirmed control failure based solely on the automated result.
- B. Reproduce the test and correlate application, intermediary, and tool records to determine the actual outcome.
- C. Discard the result because the application record shows a denial.
- D. Change the assessment criteria so the unexpected response is considered successful.

Question 16 (CISSP4-114)

Scenario: A medical device manufacturer allows temporary exceptions to its secure configuration standard. The auditor must determine whether exceptions remain controlled rather than becoming permanent undocumented deviations.

Which TWO data elements are MOST important to test? Select 2 of the 5 options below.

- A. Documented risk approval, business justification, and accountable owner for each sampled exception.

- B. Expiration, periodic review, and closure or renewal records for each sampled exception.
- C. The preferred font used in the exception request form.
- D. The total number of words in the secure configuration standard.
- E. The job titles of employees who never requested an exception.

Question 17 (CISSP4-115)

Scenario: A data archival failure destroyed three months of records needed to test a control across the full audit period. Available evidence supports only the remaining nine months, and no equivalent source exists.

How should the final report address this condition?

- A. State that the control was effective for the full year because no failure was reported during the missing period.
- B. Omit the missing period so readers are not distracted from the available results.
- C. Treat absent records as proof that the control failed in every case.
- D. Describe the evidence limitation, the period affected, and its impact on the assurance conclusion.

Question 18 (CISSP4-116)

Scenario: An external auditor requests configuration records that contain secrets and personal data not relevant to the test objective. The auditor needs the remaining fields to verify control operation.

What is the BEST way to facilitate the request?

- A. Provide a controlled, traceable copy with irrelevant sensitive fields appropriately redacted while preserving the evidence needed for testing.
- B. Send the unfiltered records through ordinary email because the auditor is independent.
- C. Refuse to provide any evidence containing sensitive information, even when protected alternatives exist.
- D. Replace the requested records with a verbal statement from the control owner.

ANSWER KEY AND EXPLANATIONS

Question 1 (CISSP4-099) - Correct: B

An assurance map shows which risks and controls receive independent review, where work is duplicated, and where material gaps remain. Repeating identical tests wastes resources, excluding ownerless interfaces preserves the gap, and isolated checklists do not provide enterprise-wide coverage visibility.

Question 2 (CISSP4-100) - Correct: D

Applicable legal or regulatory criteria cannot be displaced by a weaker internal baseline. The assessor should evaluate the mandatory requirement and may also report performance against relevant internal criteria. Convenience or owner preference does not determine compliance obligations.

Question 3 (CISSP4-101) - Correct: A

When a critical subservice organization is excluded, the customer needs separate evidence for the controls on which it relies. Provider selection is not assurance, the report's boundary cannot be expanded by assumption, and outsourcing a control does not remove the customer's need to evaluate associated risk.

Question 4 (CISSP4-102) - Correct: A, B

Approved authority and escalation provisions resolve governance questions, while named evidence owners and timelines make responsibilities clear before testing. Selective sample removal undermines completeness, undocumented procedures weaken reproducibility, and remediation remains a management responsibility after findings are evaluated.

Question 5 (CISSP4-103) - Correct: C

Automated history can support a point-in-time audit conclusion only after the assessor establishes that its sources, coverage, logic, integrity, and exceptions are reliable. Continuous collection does not make evidence self-validating, a current view omits historical operation, and the assessor need not assume operational monitoring ownership.

Question 6 (CISSP4-104) - Correct: B

A material restriction that prevents sufficient evidence must be documented, escalated, and reflected in the audit conclusion. Coverage elsewhere does not cure the limitation, silent scope changes undermine governance, and control effectiveness cannot be inferred across an untested subsidiary.

Question 7 (CISSP4-105) - Correct: D

Authorized misuse cases should exercise how the workflow responds to incomplete, guessed, and inconsistent evidence, including repeated attempts that may exploit different support agents. Normal-path testing, procedure review, and timing data do not demonstrate resistance to account-recovery abuse.

Question 8 (CISSP4-106) - Correct: A

Known test events provide an expected population that can be traced across sources, revealing missing records and timestamp misalignment. Policies and owner statements describe expectations, while an uncorrelated count cannot establish end-to-end completeness or sequencing accuracy.

Question 9 (CISSP4-107) - Correct: C

A private repository still exposes embedded credentials to cloning, history, backups, and users with repository access. The secret should be removed and rotated because earlier

versions may retain it, then stored through an approved protected mechanism. Renaming a file does not change exposure.

Question 10 (CISSP4-108) - Correct: A, B

Content-type deception and prohibited files test validation controls, while crafted names and paths test whether storage boundaries can be escaped. Branding, ordinary display speed, and instruction length do not address the identified interface-security risks.

Question 11 (CISSP4-109) - Correct: B

Penetration testing should prove the authorized objective with the least harmful evidence necessary. Bulk export, unapproved modification, or uncontrolled sharing increases privacy and operational risk without adding proportionate assurance. Evidence must remain protected and handled under the engagement rules.

Question 12 (CISSP4-110) - Correct: D

A current-state comparison detects drift after deployment, and exception validation distinguishes approved deviations from control failures. Original image approval proves only the starting state, while purchase records and administrator recollection do not establish present configuration compliance.

Question 13 (CISSP4-111) - Correct: A

Service-account assurance requires a valid business purpose, current accountable ownership, and appropriate activity. Reconciliation exposes orphaned or unexplained active accounts. Totals and naming conventions are incomplete indicators, while recent use does not prove authorization.

Question 14 (CISSP4-112) - Correct: C

An aggregate threshold can conceal a deteriorating high-risk segment. The sustained rise in overdue internet-facing findings warrants analysis and potentially a segment-specific trigger. Remaining below an enterprise total does not establish that all risk concentrations are acceptable or improving.

Question 15 (CISSP4-113) - Correct: B

Conflicting output requires reproduction and correlation across the relevant components before classification. Neither the tool nor one application record is conclusive by itself. Immediate confirmation, dismissal, or retroactive criteria changes would produce an unsupported conclusion.

Question 16 (CISSP4-114) - Correct: A, B

Controlled exceptions require authorized risk acceptance, justification, ownership, and time limits supported by review and closure or renewal evidence. Form appearance, document length, and unrelated employee titles do not demonstrate that deviations are governed effectively.

Question 17 (CISSP4-115) - Correct: D

The report must disclose the unavailable evidence and explain how it limits the conclusion. Silence is not evidence of effectiveness, omission misleads readers, and missing records alone do not prove that every underlying control action failed.

Question 18 (CISSP4-116) - Correct: A

Scoped redaction and controlled, traceable delivery protect irrelevant sensitive data while preserving sufficient audit evidence. Independence does not remove confidentiality obligations, blanket refusal may prevent valid testing, and an unsupported verbal statement

is weaker than appropriately protected records.